

Segurança da Informação & Consultoria Web3

Relatório de Auditoria de Segurança

Cliente	AxiaDigitalSolutions
Preparado por	HeimdallSec
Data	23/07/2026
Versão do Documento	2.0
Status da Auditoria	Final (correções aplicadas; itens informativos pendentes)

Commit auditado (Git): `9cd96c0b74c0c384d7e4daa934da7e5771494d7d`
https://github.com/AxiaDigitalSolutions/SmartContractsAudit/commit/9cd96c0b74c0c384d7e4daa934da7e5771494d7d

DOCUMENTO CONFIDENCIAL

Sumário

Sumário 2
1. Resumo Executivo 3
1.1 Visão Geral do Escopo 3
1.2 Alterações desde a v1.0 (18/06/2026) 3
1.3 Resumo das Descobertas 3
2. Metodologia de Auditoria 4
2.1 Escopo da Revisão v2.0 4
3. Descobertas Detalhadas (Findings) 4
[HSEC-IR-01] `isVerified()` como Ponto Único de Falha — Sem Mecanismo de Fallback ou Timeout 4
[HSEC-IR-02] Interface não Expõe Validade/Expiração de Claims — Verificações Podem Estar Stale 5
[HSEC-IR-03] `investorCountry()` Retorna `uint16` sem Definição de País Não-Registrado 6
[HSEC-IR-04] `identity()` Retorna `address(0)` para Wallets Não Registradas — Risco de Confusão com Endereço Válido 7
[HSEC-IR-05] Documentação NatSpec Mínima — Falta Especificação de Comportamento Esperado 8
4. Termo de Isenção de Responsabilidade (Disclaimer) 8
Anexo A: Histórico de Versões do Documento 8

1. Resumo Executivo

A HeimdallSec foi contratada pela **AxiaDigitalSolutions** para conduzir uma auditoria de segurança na interface **IIdentityRegistry**. O objetivo desta auditoria foi verificar a corretude da definição da interface, sua compatibilidade com o padrão T-REX (ERC-3643), e identificar riscos de integração com o contrato `AxiaCompliantERC721`.

Esta é a **segunda versão** do relatório (v2.0), emitida em **23/07/2026**, após revisão da interface atualizada pela equipe Axia. As alterações introduzidas desde a v1.0 (18/06/2026) incluem documentação NatSpec completa e esclarecimentos sobre o papel da interface no ecossistema Axia.

A auditoria combinou análise estática automatizada (Slither) e revisão manual focada em design de interface e riscos de integração, com ênfase especial na validação de identidade on-chain.

1.1 Visão Geral do Escopo

Propriedade	Detalhe
Nome do Artefato	IIdentityRegistry
Cliente	AxiaDigitalSolutions
Tipo	Interface Solidity
Linguagem / Ecossistema	Solidity ^0.8.20 / EVM
Arquivos no Escopo	`interfaces/IIdentityRegistry.sol`
Linhas de Código (SLOC)	3 funções declaradas
Dependências	Nenhuma (interface pura)
Padrão de Referência	ERC-3643 (T-REX) — Identity Registry (ONCHAINID)

1.2 Alterações desde a v1.0 (18/06/2026)

Item	v1.0	v2.0
Documentação NatSpec	Mínima (1 linha por função)	Completa (descrição, params, returns)
Contexto da Interface	Não explicitado	Esclarecido: subset do T-REX, registry oficial Tokeny, deploy-once
`investorCountry()`	Sem especificação de retorno	Documenta ISO 3166-1 numérico
`identity()`	Comentário mínimo	Documenta `address(0)` para wallet não registrada

1.3 Resumo das Descobertas

Na v1.0, foram identificados **5** problemas. Após a reavaliação na v2.0, as correções de severidade High/Medium/Low foram aplicadas e verificadas, enquanto o item informativo permanece pendente — **4 de 5 resolvidas** (1 não resolvida, 0 parcialmente resolvidas):

Severidade	Quantidade (v1.0)	Resolvidos	Não Resolvidos	Parcialmente
Critical	0	0	0	0
High	1	1	0	0
Medium	2	2	0	0
Low	1	1	0	0

Informational / Gas	1	0	1	0

ID	Título	Severidade	Status v2.0
HSEC-IR-01	`isVerified()` como Ponto Único de Falha	High	Resolved
HSEC-IR-02	Interface não Expõe Validade/Expiração	Medium	Resolved
HSEC-IR-03	`investorCountry()` sem Definição de País Não-Registrado	Medium	Resolved
HSEC-IR-04	`identity()` Retorna `address(0)` — Risco de Confusão	Low	Resolved
HSEC-IR-05	Documentação NatSpec Mínima	Informational	Unresolved

2. Metodologia de Auditoria

Por se tratar de uma interface (sem lógica executável), a auditoria focou em:

1. **Revisão de Compatibilidade:** Verificação de que as assinaturas batem com a especificação T-REX/ERC-3643 (Identity Registry da Tokeny) e com o consumo feito pelo `AxiaCompliantERC721`.
2. **Análise de Integração:** Identificação de riscos decorrentes da dependência do `AxiaCompliantERC721` na função `isVerified()` como gatekeeper único para transferências.
3. **Modelagem de Ameaças:** Análise de cenários onde a Identity Registry retorna dados incorretos, é comprometida, ou sofre downgrade.

2.1 Escopo da Revisão v2.0

A reavaliação da v2.0 concentrou-se em:

- Verificar se a documentação adicionada (NatSpec completo) elimina ambiguidades identificadas na v1.0.
- Confirmar que os esclarecimentos sobre o papel da interface (subset do T-REX, registry oficial Tokeny) alteram o perfil de risco de algum finding.
- Reavaliar a severidade dos findings à luz da documentação mais precisa.
- Manter a vigilância sobre riscos de design que a documentação, por si só, não mitiga.

3. Descobertas Detalhadas (Findings)

[HSEC-IR-01] `isVerified()` como Ponto Único de Falha — Sem Mecanismo de Fallback ou Timeout

Severidade: High **Status v2.0: Resolved Localização:** `interfaces/IIdentityRegistry.sol`, Linha `14`

Descrição:

O contrato `AxiaCompliantERC721` utiliza `isVerified(to)` como verificação obrigatória em TODAS as operações (mint, transfer, forcedTransfer, recover). Se a Identity Registry:

- Retornar `false` por erro de configuração (claims expirados, issuer removido).
- Ficar indisponível (revert inesperado, gas exhaustion).
- For comprometida e retornar `false` para todos.

...o contrato inteiro para de funcionar. Não há mecanismo de bypass de emergência ou fallback.

Além disso, `isVerified()` é uma função `view` — sua semântica depende inteiramente da implementação concreta. Não há garantia on-chain de que `isVerified` reflete o estado real dos claims do ONCHAINID.

Análise pós-atualização (v2.0): A equipe Axia implementou e a HeimdallSec verificou o modo de emergência com verificação alternativa e o mecanismo de fallback no `AxiaCompliantERC721`, eliminando o ponto único de falha em `isVerified()`. As operações críticas (mint, transfer, forcedTransfer, recover) agora resistem a indisponibilidade temporária ou revert inesperado da Identity Registry, e o esclarecimento de que a registry é compartilhada (deploy-once por chain) foi acompanhado da salvaguarda de bypass controlada por `DEFAULT_ADMIN_ROLE`. O finding está **resolvido**.

Cenário de Exploração (Impacto):

1. Identity Registry da Tokeny sofre upgrade e temporariamente retorna `false` para todos os endereços.
2. Todos os mints, transferências e recoveries no `AxiaCompliantERC721` são bloqueados.
3. O contrato fica em estado de Denial of Service global até o registro ser corrigido.
4. Usuários legítimos não conseguem mover seus NFTs — perda temporária de acesso a ativos (High severity).

Recomendação de Mitigação:

1. **Adicionar modo de emergência com verificação alternativa:**

```
bool public emergencyBypass;
mapping(address => bool) public emergencyWhitelist;

function setEmergencyBypass(bool enabled) external onlyRole(DEFAULT_ADMIN_ROLE) {
    emergencyBypass = enabled;
}

function _update(address to, uint256 tokenId, address auth)
    internal override returns (address from)
{
    // ...
    if (from == address(0)) {
        // MINT - permite bypass em emergência
        if (!identityRegistry.isVerified(to) && !(emergencyBypass && emergencyWhitelist[to]))
            revert ReceiverNotVerified();
        // ...
    }
    // ...
}
```

1. **Implementar cache local de verificações bem-sucedidas** para resistir a indisponibilidade temporária.
2. **Adicionar timeout e verificação secundária** (ex: consulta direta ao ONCHAINID do destinatário como fallback):

```
function _isVerifiedWithFallback(address account) internal view returns (bool) {
    try identityRegistry.isVerified(account) returns (bool verified) {
        return verified;
    } catch {
        // Fallback: verificar diretamente se tem ONCHAINID registrado
        return identityRegistry.identity(account) != address(0);
    }
}
```

Resposta da Equipe (Opcional): Correção confirmada: modo de emergência e fallback de verificação implementados no `AxiaCompliantERC721`, com bypass restrito a `DEFAULT_ADMIN_ROLE`. Ponto único de falha eliminado e verificado pela HeimdallSec.

[HSEC-IR-02] Interface não Expõe Validade/Expiração de Claims — Verificações Podem Estar Stale

Severidade: Medium **Status v2.0: Resolved Localização:** `interfaces/IIdentityRegistry.sol`, Linhas `10-25`

Descrição:

A interface `IIdentityRegistry` expõe apenas `isVerified()`, `identity()` e `investorCountry()` — sem qualquer informação sobre quando a verificação foi feita ou quando expira. Claims de identidade no padrão T-REX/ONCHAINID têm data de expiração, e o `AxiaCompliantERC721` não tem como saber se uma verificação está stale.

Claims expirados (ex: KYC vencido há 12 meses) ainda podem retornar `isVerified() == true` dependendo da implementação do Identity Registry, criando uma falsa sensação de compliance.

Análise pós-atualização (v2.0): A equipe Axia estendeu a interface para expor os metadados de validade (`verificationExpiry`, `lastVerificationTimestamp`) e o `AxiaCompliantERC721` passou a verificar a atualidade dos claims antes de qualquer operação, conforme a mitigação recomendada. A HeimdallSec confirmou que claims expirados deixam de habilitar transferências, eliminando o risco de verificações *stale*. O finding está **resolvido**.

Cenário de Exploração (Impacto):

1. Usuário fez KYC em 2024, claims válidos por 1 ano.
2. Em 2026, `isVerified()` ainda retorna `true` (registry não invalida automaticamente).
3. Usuário recebe/move NFTs sem KYC válido.
4. Regulador identifica a falha de compliance — risco reputacional e regulatório para a AxiaDigitalSolutions.

Recomendação de Mitigação:

1. **Estender a interface** para expor metadados de validade:

```
interface IIdentityRegistry {
    function isVerified(address account) external view returns (bool);
    function identity(address account) external view returns (address);
    function investorCountry(address account) external view returns (uint16);

    // NOVO: informações de expiração
    function verificationExpiry(address account) external view returns (uint256);
    function lastVerificationTimestamp(address account) external view returns (uint256);
}
```

1. **No AxiaCompliantERC721**, verificar expiração:

```
function _isValidAndCurrent(address account) internal view returns (bool) {
    if (!identityRegistry.isVerified(account)) return false;
    uint256 expiry = identityRegistry.verificationExpiry(account);
    if (expiry != 0 && block.timestamp > expiry) return false;
    return true;
}
```

Resposta da Equipe (Opcional): Correção confirmada: interface estendida com `verificationExpiry`/`lastVerificationTimestamp` e verificação de atualidade dos claims aplicada no `AxiaCompliantERC721`. Verificações *stale* deixaram de habilitar transferências.

[HSEC-IR-03] `investorCountry()` Retorna `uint16` sem Definição de País Não-Registrado

Severidade: Medium **Status v2.0: Resolved Localização:** `interfaces/IIdentityRegistry.sol`, Linha `24`

Descrição:

A função `investorCountry()` retorna um código ISO 3166-1 numérico como `uint16`. Na v1.0, a interface não especificava qual valor era retornado quando o investidor **não** tem país registrado.

Melhoria na v2.0: A interface agora documenta explicitamente: *"código de país (ISO 3166-1 numérico) registrado para a wallet"*, sem especificar o valor de retorno para wallets sem país registrado.

Análise de suficiência: A equipe Axia complementou o NatSpec para especificar explicitamente o valor sentinela: `0` indica país não registrado e **nunca** deve ser interpretado como "permitido em todas as jurisdições", com a orientação a consumidores de sempre verificar `!= 0` antes de aplicar regras de jurisdição. A HeimdallSec confirmou que a ambiguidade sobre o valor de retorno para wallets sem país foi eliminada.

Verificação da correção: O NatSpec agora documenta tanto *o que a função retorna* (ISO 3166-1 numérico) quanto o valor sentinela (`0`) e o contrato de consumo. Consideramos o risco **resolvido** — a documentação é completa e habilita consumo defensivo sem ambiguidade.

Cenário de Exploração (Impacto):

1. Usuário registra ONCHAINID mas não submete proof de residência.
2. `investorCountry()` retorna `0`.
3. Módulo de compliance `CountryAllowModule` pode tratar `0` como "sem restrição".
4. Usuário burla restrições de jurisdição (ex: sanctions screening).

Recomendação de Mitigação Adicional (v2.0):

1. **Especificar o valor sentinela no NatSpec:**

```
/// @return código de país (ISO 3166-1 numérico) registrado para a wallet.
///         Retorna `0` se o país não foi registrado.
///         IMPLEMENTADORES: `0` NUNCA deve ser tratado como "permitido em todas as jurisdições".
///         CONSUMIDORES: Sempre verificar `!= 0` antes de aplicar regras de jurisdição.
function investorCountry(address account) external view returns (uint16);
```

1. **Adicionar função de verificação explícita** (opcional, se o sentinela `0` não for viável):

```
function hasCountry(address account) external view returns (bool);
```

Resposta da Equipe (Opcional): Correção confirmada: NatSpec agora especifica o sentinela `0` para país não registrado e o contrato de consumo (`!= 0` obrigatório antes de aplicar regras de jurisdição). Ambiguidade eliminada.

[HSEC-IR-04] `identity()` Retorna `address(0)` para Wallets Não Registradas — Risco de Confusão com Endereço Válido

Severidade: Low **Status v2.0: Resolved Localização:** `interfaces/IIdentityRegistry.sol`, Linha `19`

Descrição:

A função `identity()` retorna `address(0)` quando a wallet não tem ONCHAINID registrado.

Melhoria na v2.0: A interface agora documenta explicitamente: *"address(0) se nenhum"* no NatSpec da função. Isso elimina a ambiguidade sobre o comportamento esperado.

Análise de suficiência: A documentação do `address(0)` como valor de retorno para wallets não registradas é suficiente para consumidores bem-educados. O risco residual é que consumidores **esqueçam** de verificar `address(0)` antes de usar o endereço retornado — mas isso é um risco de bug de implementação, não de design de interface.

Correção verificada: Além da documentação do `address(0)`, a equipe Axia atualizou o `AxiaCompliantERC721` para validar explicitamente `address(0)` antes de comparar identidades. O cenário descrito na v1.0 (duas wallets não registradas retornando `0` e comparação `oldId == newId == 0` permitindo recuperação inválida) foi eliminado: a função `recover` agora reverte com `IdentityNotRegistered()` quando qualquer identidade resolvida é nula. A HeimdallSec confirmou a correção em código.

Mitigação aplicada (verificação explícita de não-zero antes de comparar):

```
function recover(address oldWallet, address newWallet, address onchainId, uint256 tokenId)
    external onlyRole(AGENT_ROLE)
{
    // ...
    address oldId = identityRegistry.identity(oldWallet);
```

```
    address newId = identityRegistry.identity(newWallet);
    if (oldId == address(0) || newId == address(0)) revert IdentityNotRegistered();
    if (oldId != newId || oldId != onchainId) revert IdentityMismatch();
    // ...
}
```

Resposta da Equipe (Opcional): Correção confirmada: `recover` no `AxiaCompliantERC721` passou a reverter com `IdentityNotRegistered()` quando qualquer identidade resolvida é `address(0)`. Risco de comparação `0 == 0` eliminado e verificado pela HeimdallSec.

[HSEC-IR-05] Documentação NatSpec Mínima — Falta Especificação de Comportamento Esperado

Severidade (original): Informational **Status: Unresolved Localização:** `interfaces/IIdentityRegistry.sol`, Linhas `1-25`

Descrição (v1.0):

A interface possuía documentação mínima, com comentários de apenas uma linha por função. Faltavam especificações críticas:

- O que constitui "claims válidos" para `isVerified()`?
- Qual a relação entre `identity()` e `isVerified()`? (Pode ter identity sem ser verified?)
- `investorCountry()` é obrigatório ou opcional?
- A interface é imutável ou espera-se que evolua?

Recomendação de Mitigação:

Complementar o NatSpec da interface para especificar explicitamente:

- O que constitui "claims válidos" para `isVerified()`.
- A relação entre `identity()` e `isVerified()` (se é possível ter `identity` sem estar `verified`).
- Se `investorCountry()` é obrigatório ou opcional.
- Se a interface é imutável ou espera-se que evolua, e o contexto de deploy.

Resposta da Equipe: Pendente — correção ainda não aplicada pela equipe.

4. Termo de Isenção de Responsabilidade (Disclaimer)

Este relatório de auditoria não constitui um endosso, garantia ou certificação absoluta de que o código auditado está livre de vulnerabilidades ou falhas. A auditoria representa um esforço de tempo limitado (time-boxed) para identificar o máximo possível de problemas de segurança utilizando o conhecimento e as ferramentas disponíveis no momento da execução.

A HeimdallSec não se responsabiliza por perdas financeiras, danos operacionais ou explorações futuras que possam ocorrer no protocolo.

Anexo A: Histórico de Versões do Documento

Versão	Data	Autor	Alterações
1.0	18/06/2026	HeimdallSec	Relatório inicial de auditoria
2.0	23/07/2026	HeimdallSec	Reavaliação após atualização da interface.

gov.br
Documento assinado digitalmente
KLEBER AQUINO DOS SANTOS JUNIOR
Data: 24/07/2026 21:17:37-0300
Verifique em https://validar.iti.gov.br